

Risiko	Beispiel	Schutzmaßnahme
Gering	Kein Zugriff auf interne Systeme	Standard-Passwortschutz
Mittel	Zugriff auf Kundendaten	2FA, Verschlüsselung
Hoch	Verarbeitung sensibler Daten	Härtung, Netzwerksegmentierung, Monitoring

11.15 ISMS

Ein ISMS (Information Security Management System) ist ein systematischer Ansatz zur Planung, Umsetzung, Überwachung und Verbesserung der Informationssicherheit in einer Organisation. Es basiert auf definierten Richtlinien, Prozessen und technischen Maßnahmen.

Bestandteile

- **Sicherheitsrichtlinien:** Vorgaben zur IT-Sicherheit und Datenschutz.
- **Risikomanagement:** Identifikation, Bewertung und Behandlung von Sicherheitsrisiken.
- **Technische & organisatorische Maßnahmen:** Firewalls, Verschlüsselung, Schulungen.
- **Überwachung & Audits:** Regelmäßige Prüfungen zur Einhaltung der Sicherheitsstandards.
- **Kontinuierliche Verbesserung:** Anpassung an neue Bedrohungen und Anforderungen.

Relevante Standards

- **ISO 27001:** Internationaler Standard für ISMS-Zertifizierung.
- **BSI IT-Grundschutz:** Deutscher Standard für IT-Sicherheit.

Vorteile

- Schutz sensibler Daten vor Cyberangriffen und Datenverlust.
- Einhaltung gesetzlicher Anforderungen (z. B. DSGVO, IT-Sicherheitsgesetz).